

# The Future of Identity and Access Management

Ronald Ritchey, Ph.D.

This chapter provides 10 predictions for the future of identity and access management.

## Keywords

Prediction; forecast; identity ecosystem; NSTIC; National Strategy For Trusted Identities in Cyberspace; role-based access control; RBAC; attribute-based access control; ABAC; identity and access management; IAM

This book provides guidance to assist enterprises in adopting successful identity and access management (IAM) business strategies and practices. It presents an action plan to help organizations develop an effective IAM strategy as part of a holistic management approach. Using this approach, organizations can manage risk associated with identity and access, optimize key business processes, leverage investments in technology, enable employee and partner effectiveness, and manage the growing information needs of its businesses.

It is important in developing your strategy to have some sense for where identity and access management is heading. With the pace of invention and changing market dynamics in information technologies, predictions are a dangerous game. That said, to develop a strong IAM strategy, one has to place a few bets—in essence, making predictions of your own. Here is our top 10 predictions to assist you in developing your path.

## 1 Password-Based Authentication. To Paraphrase Mark Twain, the Reports of its Death Have Been Greatly Exaggerated

Security experts have been talking about the death of passwords for almost as long as we've been using them. They have a point. Passwords have many deficiencies. Passwords chosen by people—whether they are for sensitive financial transactions or social media accounts—tend to be weak. Even well-chosen passwords can be compromised through phishing attacks or if the device you enter the password into has been compromised with malware.

And then there is the issue of credential theft and the magnification of risk associated with password sharing. To simplify their lives in the face of having to remember hundreds of passwords, people tend to re-use passwords for a wide variety of services and accounts. This means that a compromise of a password credential in one environment damages the security of all of them.

*So why are we still using them?*

There are four main reasons.

1. Passwords are cheap to use.
2. Passwords are easy to establish.
3. Passwords are the existing standard.
4. There is insufficient recognition of the need for change.

## **Cheap**

Password-based authentication is built into every platform that you are likely to interact with. Even if it wasn't, writing password management logic is not difficult (though frequently messed up anyway). In addition, there is no need for any special infrastructure to use passwords. You do not need sensors such as fingerprint readers, microphones, or cameras. You do not need hardware tokens or smartcards. And most importantly, you do not need a special support infrastructure to distribute and maintain these devices.

## **Easy**

People have been choosing and entering passwords as long as they have been using computers. While people may not choose good passwords and may frequently forget them, they are comfortable with the process. The impact to most people of a bad password choice is zero, unless their account is compromised because of it. If they forget their password, most systems have easy and automated methods for the user to reset their password. Passwords also do not require the person to carry around with them additional credentials or hardware. So, discounting the lack of security, from most people's perspective, passwords deliver a reasonably good user experience.

## **Existing Standard**

It's hard to overstate the advantage of being the existing standard for a highly visible core service. There will be substantial resistance to change across multiple stakeholder communities. People will not want change that decreases the quality of their user experience, technologists will not want change that decreases availability or performance, and business owners will not want change that drives large increases in cost. Even if the decision is made to move to higher quality authentication, the change will not come overnight and will not be comprehensive. There will always be services where the cost of migration is just not warranted.

given the risk profile of the service. So unless or until these systems are retired, passwords will remain a feature of these environments.

## Insufficient Recognition of the Need for Change

Many people have little perception of the amount of risk they are exposed to by the use of password-based authentication. While there have been many news stories highlighting these risks, the amount of adoption of more secure authentication—even in environments that offer it—has been low especially if passwords remain the default choice. A good example of this is Google’s popular Gmail service. Gmail has offered their customers the option of using two factor authentication since the beginning of 2011 yet even after high profile incidents<sup>1</sup> involving the theft of Gmail passwords and subsequent account takeovers, the number of customers who use Google’s two factor service is a tiny fraction of their user-base.

Passwords are simply too ubiquitous, too accepted, and too useful to die. Don’t take this to mean that change is not coming. It is. Specific technologies, strategies, and approaches are being developed to address each of these major challenge areas and progress is being made. It is expected to take several years to reach a tipping point where authentication is not primarily password based. So while we will not have to rely exclusively upon passwords forever, they will remain an important component of our authentication environment for the foreseeable future.

## 2 It’s Not Your Voice That Will Be Your Password, but It Will Be Your Phone

One of the biggest challenges in offering enhanced authentication is the additional infrastructure it often requires. While not universally true for all forms of advanced authentication, moving beyond passwords normally requires you to issue a physical credential to each of your people. Even with biometric authentication you still need an infrastructure of readers that can take the necessary physical measurements. This is one of the major cost drivers for enhanced authentication.

Instead of issuing all of these expensive devices, imagine if all of your people already owned a device that you could use to securely authenticate them. It would be even better if that device contained sensors that could also be used to implement some form of biometric authentication. Well, many—if not most—of your people already own this type of device in the form of their smartphones. Current smartphones offer a unique platform on which to base high-quality authentication services. Smartphones can host and manage multiple credentials, they have sensors that can be used to enable biometric authentication and other types of authentication attributes, and they are inexpensive, at least from the perspective that so many of your people will already own one for other purposes. Let’s take a look at each of these advantages.

## Secure Hosting of Credentials

Modern smartphone operating systems including Google Android, Apple IOS, and Blackberry have implemented services that provide a strongly protected security container that can be used to securely store secrets including encryption keys, passwords, and other types of security tokens. This provides the opportunity for organizations to store the secrets necessary to enable many types of enhanced authentication on the smartphone in a reasonably secure fashion. It also allows many different credentials to be established on the same device, eliminating the need for the person to carry separate tokens for every environment to which they wish to authenticate.

The robustness of these containers though does vary based upon the version of the OS and the type of phone. Older designs attempted to manage the secure storage service purely in software where it is much more difficult to provide comprehensive protection. The most secure designs include specific hardware extensions that provide tightly controlled interfaces that limit how software on the device can interact with the secure storage area.

## Sensors

Smartphones come with many sensors that can be used to enhance authentication. One of the most basic is the microphone. There are many companies offering systems that leverage the microphone for voice biometrics. The camera is also frequently used to enable biometric authentication including palm print and facial recognition.

In addition to biometrics, there are other sensors on these devices that can enhance authentication, such as assisted GPS services that combine a GPS receiver with information derived from the Wi-Fi radio. This means that you can now make authentication decisions based upon where a person is located, opening up many new opportunities to enhance authentication. Have a need to restrict access to sensitive data when traveling abroad? The smartphone has the location data needed to make the right decision.

The Bluetooth radio can also be used to offer an authentication service in the form of proximity detection. This can be used to prevent a login from succeeding unless the smartphone is in close proximity to the device being used to access the desired service. Perhaps more importantly, it can be used to lock a device if the space between the smartphone and the device exceeds a reasonable distance, thus preventing an unattended device or a device that is stolen while logged in from being used by unauthorized individuals.

## Low Cost

A few years ago, the penetration of smartphones into the marketplace was fairly low but this is changing rapidly. According to a recent study by the Pew Internet & American Life Project<sup>2</sup>, 56% of adult Americans own some form of smartphone. Because of this, for many organizations, the marginal cost of leveraging the person's existing smartphone as a credential is exceedingly low.

While offering a promising alternative, smartphones do come with security concerns and authentication issues. One major concern is the security of the device itself. Smartphones have become a primary target for malware authors. If a person's device becomes compromised, it is likely that the credentials stored within it will be compromised as well. To counter this threat, newer phones are including trusted computing devices that strongly resist removal of their secrets. This problem is no different than the challenge of protecting other computing devices (e.g., laptops, desktop) used to access network services.

Another concern is addressing the inevitable set of people who do not have, or who do not want a smartphone. This is an addressable problem. The affordability threshold is dropping; prices are coming down at rapid rates and most smartphone-based authentication techniques can be supported with technology older than the latest production models. Smartphones even one generation back can be inexpensively purchased. For people who do not want smartphones or in emerging markets where smartphone adoption is significantly lower, alternative authentication methods, such as a fallback to username and password, can be supported.

### **3 Biometrics Authentication Will Remain a Niche for Primary Authentication**

The use of fingerprint, facial, eye (iris/retina) and voice recognition have a science fiction, futuristic feel. However, many of these biometric techniques work and work well. So, why are the deployments of biometric authentication so limited? This authentication method struggles with three serious problems: lack of infrastructure, user acceptance, and privacy concerns.

#### **Lack of Infrastructure**

The first issue, infrastructure, refers to the need for some form of sensor to collect the biometric data. While there has been significant progress leveraging existing infrastructure sensors such as webcams and (as mentioned previously) smartphones, most biometric deployments rely upon the presence of sensors that are dedicated to authentication. This allows the sensors to be tuned for its purpose, increasing accuracy and improving the ability to reject attempts to provide previously recorded biometric data (e.g., liveness checks). Adding to the hurdle is the expense. Purchasing, deploying, and installing biometric infrastructure can be expensive if done as a discrete effort. This cost would be mitigated if major device manufacturers included biometric sensors as part of their normal product configuration. Some manufacturers are doing exactly that,



but uptake from consumers and companies has been inconsistent, and little market advantage is being conveyed by their presence.

## User Acceptance

The second hurdle is user acceptance. Biometric systems need to be reliable and fast, at least in comparison to what they are replacing. If it takes multiple attempts to get a good reading before access is granted, people will quickly become frustrated by the system. Next, people may worry about the theft of their personal biometric data with the subsequent risk that they can now be impersonated. If an adversary captures a high-quality recording of the feature being used for authentication, it is technically feasible that the adversary can replicate a copy that would be accepted by the biometric authenticator. In reality, this is more difficult to do than it would appear but is still a concern and unlike with passwords, if someone's biometric data is stolen, there is no way to reset the authentication.

## Personal Safety and Privacy

The third challenge is the concern about personal safety and privacy. Unfortunately, there have already been cases where criminals have cut off the fingers of their victims in order to authenticate using the person's fingerprints.<sup>3</sup> "Liveness" checks that ensure that the biometric is being read from a real and live person are a standard part of most biometrics systems but (a) they are not perfect and (b) the criminals need to know that they exist.

A much more rational fear is the potential that a person's biometric information will be used to breach their privacy. Once collected, it is possible to use the biometric information to identify a person in situations where they may not wish to be identified. Some stores are experimenting with tracking customers who come into the stores using facial recognition technology even if the customer does not make a purchase. More concerning is the potential for large-scale population surveillance using biometric identification. This is a real possibility as the technology continues to improve and the infrastructure of public cameras increases in number and sophistication.

All this is not to say that biometrics should be shelved. Governments are increasing the use of biometric authentication especially for applications like immigration control, where the ability to accurately identify a person, even if they are attempting to impersonate someone else is critical. People conducting financial transactions are also increasingly being authenticated using biometric techniques including at point of sale and at ATMs. Probably the largest scale deployments though will occur if smartphone and tablet manufacturers start including biometric readers to unlock devices. This application would be a substantial improvement in both the security and the convenience to access these devices, making it a perfect use case for biometrics.

## 4 Access Decision-Making Will Become Context Aware

Traditional access decision-making is static. It happens during provisioning when a person is first authorized to access a system, service, or function within an environment. Once the people are provisioned, access is granted whenever they request it once they have properly authenticated. It doesn't matter when, where, or why the person is requesting the service. This is increasingly insufficient in today's environments, as it does not allow organizations to make good, risk-based decisions based upon the context of the request.

There are many situations where basic context can add substantial security value. For instance, banks have long used the location, type, and value of credit card purchases as a strong indication for the validity of a purchase. When a customer suddenly starts purchasing from a vastly different location, on different types of merchandise above their normal buying patterns, the transactions may be denied until the bank can verify that the transactions are valid. These approaches allow the banks to dramatically limit fraud loss while providing efficient service to the vast majority of customers' transactions.

The same types of approaches can be used in the broader context of access management. The challenge is understanding the specific risks that you are trying to manage and then coming up with the right contextual data to help manage that risk. An example will help illustrate the concept.

If you decide to finance a new car purchase, the auto dealer would need to be able to perform a credit check for you before they could process your loan application. However, it would be a violation of the terms of agreement of the credit reporting agencies and unethical for the dealer to run credit reports for people not purchasing a car. If permission to access the credit check function were static, there would be no simple way to prevent the dealer from abusing the privilege. Add some context and the risk can be easily managed. The best contextual attribute for this would be the name of the applicant. The access decision for the credit check function could limit access so that reports can only be run for people with active car loan applications. That attribute might not be readily available, though, so an alternate approach would be to limit the number of requests for checks to a number that is the same (or at least close) to the number of applications the dealer is processing.

Location will be one of the most used context attributes. There are many situations where the risk of providing a service is significantly impacted by where that access is being provided. For example, a company may not want sensitive documents to be transferred to a laptop if that computer is currently operating from an area that has a reputation for large amounts of information theft. Or, an organization might want to disable features of a smartphone, such as the camera and microphone, when the person enters a sensitive area within a building such as a boardroom.

There are many technical and policy challenges to enabling context-based access management, but they are being solved. The technical challenges center on the large number of systems that still make all of their access decisions based upon locally managed access policies. However, there is a strong movement away from these stove-piped access management systems to externalized access decision engines that allow more complex access logic to be applied across a set of systems and services. The harder long-term challenges are the development and maintenance of context attribute repositories and the development of the policies that leverage these attributes to make risk-based decisions. Fortunately, many companies are already tackling these issues and are finding ways to collect key contextual attributes and leverage them to write more flexible and powerful access policies.

## 5 The Identity Ecosystem Will Finally Emerge

Identity management remains largely stove-piped, with each service maintaining separate and distinct records of identity. This creates a number of specific challenges. Most, if not all, of the sites a typical person accesses will rely upon username/password-based authentication. To maintain good security, the person should choose strong passwords for every site they wish to access and should not share passwords between sites. However, it is not uncommon for people to have dozens, if not hundreds of sites that they periodically visit. As any person can attest, the more sites they visit that require passwords, the more difficult it becomes to manage them. Maintaining distinct, high-quality passwords for each site or application is not reasonable. However, if a person shares passwords between sites, there is the real danger that a security breach at one site will compromise that person's security on many sites. The trade-off many people make is to have shared passwords across lower risk sites but separate passwords for high-risk sites like banking and ecommerce.

It would be much better if people were able to leverage high-quality credentials for the sites they need to access. In the current stove-piped environment this would be prohibitively expensive and inconvenient. Imagine having to have a pocket full of tokens to be able to access all of the sites you regularly do business with. It would be far better if people had a limited set of high-quality credentials that could be used anywhere they need to use them. This is the primary argument for the identity ecosystem.

The identity ecosystem proposes that a set of identity providers be established that are in a position to strongly authenticate people on behalf of organizations (referred to as relying parties) that need to grant access to their services. There are two primary responsibilities that these identity providers would need to perform. First, they need to ensure that the individuals that they authenticate are in fact who they say they are. Second, they need to bind a high-quality credential to that person. The combination of these two features would allow the various relying parties to have high confidence that when a person authenticates to them using one of the identity providers' credentials, that they were in fact dealing with a known and authorized individual.



Neither of these responsibilities is particularly easy, but some organizations already perform high-quality identity vetting and credentialing as part of their primary business. Banks for instance are required to verify the identity of their customer as part of their regulatory responsibilities through Know Your Customer (KYC) rules. Cloud providers like Google are now offering enhanced credentials to enable people to log in more securely. So, these services are already being performed. The challenge is making these services available to a broad set of relying parties.

There are several key issues that have been holding back the identity ecosystem. An initial set of technical issues have largely been solved. More challenging are the economic and legal issues that need to be resolved. The cost of performing the identity vetting and managing the credentials associated with those identities at large scale is significant. Coming up with the economic models that provide sufficient return on these investments is essential for the success of the ecosystem. Another key issue is liability. If a fraudulent login does occur that results in economic loss, which entity should be legally responsible? If a login fails because the identity provider services are temporarily down, do the relying parties have the right to sue for loss of revenue associated with the subsequent downtime? Placing large legal burdens on the identity providers will create substantial barriers to the emergence of the marketplace.

These are sticky issues that are going to be difficult to resolve but at the macroeconomic level, there is just too much to lose for us to not move in the directions of establishing identity ecosystems. Large-scale password breaches have become common as adversaries have pivoted to targeting password-based credential stores. Especially for high-risk services, there is a need for higher confidence measures that people are authentic. But trying to solve this individually with every organization duplicating investments in high-quality credentialing is extremely inefficient. So, while the establishment of the ecosystem has been slow, it is close to the tipping point where both the need is clear and immediate, the solution is well articulated, and the stakeholders are emerging to participate.

## 6 Privacy Will Take a Back Seat to Security

As a society, we have an expectation of privacy. We want to be able to limit and control the information we share, whether it is personal information to our employers, our habits to marketing firms, financial information to our creditors, or any information that we feel jeopardizes our personal autonomy. On the other side of a transaction, the organizations that we do business with need to ensure that the services that they are providing are only available to the authorized and valid user of those services. Unfortunately, the information that they collect to confirm a person's identity and validity can potentially be used in ways that create privacy concerns.

Because of this, substantial effort has gone into creating technologies and approaches that allow people to assert partial facts about themselves while not revealing more than is needed. For example, a transaction may have an age restriction, such as requiring a user to be 18 or older. Traditionally, this would require verification of the person's date of birth, which may not be something the person wished to disclose. Using privacy-preserving techniques, the person could assert a claim that he or she was over 18 years old without revealing the exact age or date of birth. Unfortunately, truly protecting the person's right to control the private data is both technically hard and at odds with the commercial interests of many of the organizations that the person does business with.

While privacy-preserving technologies are available and will be pushed into the marketplace, it is too easy to assemble detailed profiles of individuals by the collection and correlation of small facts contained within the large databases of personal information that exist today. These big data approaches can disambiguate partial identity data to build very complete personal profiles. This is especially true in situations requiring the person's name to be disclosed. It is easy for that one piece of information to be combined with other "small" pieces of data to build a complete profile of the person. This could include shopping habits, tastes, and even people the person knows. This information is used by companies to improve services to customers by offering them products specific to their tastes and needs. It can also be used to help companies make better risk-driven access control decisions.

The more you know about your users, the more context that can be created around the transactions that they are requesting from your data systems. For instance, if you knew that a person was traveling internationally on vacation, it is possible that they might login to send or receive a few emails. However, it would be suspicious if the person suddenly started downloading large volumes of sensitive documents from a computer located within the office. The challenge now is to balance the need for this context with the collection, storage, and protection of the underlying private attributes, especially where these attributes have financial value in other business contexts (e.g., marketing).

Even if we build systems that help people control their private data, huge amounts of data are still being collected all the time. This is a policy issue, not a technical one. We could spend a large amount of effort to create technical solutions that help people control how much private data they share, which would seem to increase the person's privacy. However, it is straightforward for organizations to discover the facts that people are trying not to share. So, we would be doing a lot of work that will not translate into any real privacy value. It's simply too easy to breach privacy restrictions. Once even small amounts of data are placed online they become available for sale and the cycle continues.

It would also be foolish to ignore the availability and value of private personal data. If information is available that materially improves the quality of access decisions, why wouldn't you want to use it? That said, organizations should carefully consider what information they need, how long they need it, and what

their responsibilities should be in protecting the information. There is the potential for backlash against the use of private data, especially if the use appears significantly at odds with the person's best interests. Having a clear description of how private data is enhancing the person's interactions with your organization and how you are protecting that information may go a long way in protecting your organization from claims of impropriety.

## **7 Increasing Use of Cloud Services Will Drive Adoption of Federated Authentication**

Cloud adoption, while not happening as fast as some predicted, is clearly a major trend within information technology that will continue to expand over time. The power and flexibility offered by on-demand computing services is compelling, but controlling access to cloud-based services remains a challenge for many organizations.

The basic problem is the need to make consistent authentication and access management decisions across a variety of different technical environments. This problem is similar to the need to manage identity across the different technology stacks across an internal data center. Because migrating our internal solutions to account for the extended reach of cloud environments is a long-term challenge, significant work has already gone into solving it.

There is no shortage of protocols that have emerged to solve various aspects of the problem (e.g., OAuth, XACML, SAML, SCIM,), but complex protocols like XACML have been slow to be adopted in cloud environments. Complexity is antithetical to the cloud environment, where most of the value comes from the commoditization of the provided service. Protocols like OAuth however have taken a light-weight approach that attempts to solve the most clear and compelling federated authentication use cases. Unfortunately in many situations, this simplicity limits what can be accomplished.

Ultimately, the need to manage identities consistently between corporate and cloud systems will provide the impetus to solve the challenges associated with federated access management. The resulting solutions will likely be hybrid models that make use of the best features of several combined protocols.

## **8 Entitlement Management Will Shift from Being Technology Centric to Business Centric**

Managing the set of access entitlements associated with a population of people remains a challenge, especially in environments with large numbers of people and systems. It is made more challenging by the way entitlements are typically defined. Most entitlement names are created based on the context of the

developer, not the user. These names often have little relationship to the business purpose for the entitlement. To the user, they are little more than cryptic labels. This makes the task of selecting which entitlements are necessary (or validating that the assigned set is appropriate) extremely difficult.

Even when attempts are made to document entitlements using business language definitions, they are often still difficult to understand because they can be at too low a level to map well to the user's understanding of the task or process they support. This is especially true in situations where applications are exposing fine-grained entitlements. As an example, in one popular order management system, a manager needs more than a dozen different entitlements to support the ability to both enter orders and approve their employee's orders. From the manager's perspective, trying to understand whether all of the entitlements are necessary to accomplishing a specific job remains a difficult proposition.

To solve this, entitlement management needs to shift from developer centricity to business-level constructs that combine entitlements into higher level functions that map to the business problem they are solving. In short, companies need to model access to the actual business service they provide. Take for instance the need for a financial services worker to check a credit application. In the underlying systems and applications that make up this function, there may be several individual permissions that need to be assigned to the employee. However, there is no value to exposing this to the employee or the employee's manager. To the employee, it is one clear business function. If during an access review, a manager was asked whether their employee needed to perform credit checks, the answer should be easy based upon the work that employee is tasked to perform. However, if the individual entitlement definitions were provided instead, the task of review becomes all but impossible. This is a real problem as the typical response to this unfathomable complexity is to rubber-stamp these reviews, which leads to excessive entitlements being maintained within the environment.

The value in migrating to business task-based entitlements is clear, but the path forward is daunting. Moving from system-centric definitions is made difficult by the size and complexity of existing environments. Role-based access control was one attempt to address this, but it brought access decisions up to too a high level. In many RBAC deployments, it is just as big a challenge to know whether the entitlements that are contained within a role are appropriate as it was to determine whether the specific entitlements assigned to a person were appropriate.

Technologies that help to externalize access management decisions are useful in striking the right balance. Moving the access decisions out of the applications themselves enables management of the application permissions at a higher level. With these systems, combinations of entitlements can be defined and then used to craft higher level access management policy statements.



## 9 Access Governance Will Become (Near) Real Time

Access governance has become increasingly important. This is especially the case in regulated environments that have specific requirements to periodically verify that an employee's accesses remain appropriate for their position and role within an organization. Unfortunately, the approach taken for most organizations is to perform these reviews on a fixed schedule that is not directly tied to any specific risk events or triggers. This can leave unnecessary and potentially high-risk entitlements assigned in the environment for extended periods of time. It can also lead to substantial wasted effort when low-risk or routine entitlements are being reviewed according to a fixed schedule when no real change has occurred to the person's responsibilities or status.

While still an emerging approach, there are organizations that are beginning to distance themselves from time-based reviews and instead are moving to strategies that only perform reviews of entitlements when specific risk-based triggers are encountered. This enables these organizations to focus managers' time on making decisions when there are real risk issues to address, instead of taking the boil the ocean approach of trying to review everything, every time. The specific risk triggers that are being used vary based upon the type of organization. One common risk-based trigger is a transfer review. When an employee is being transferred to a new position within an organization, it is likely that their responsibilities will change. It is important for the set of entitlements that the employee needed for their old responsibilities to be clearly identified for both the manager losing the employee and the manager receiving the employee. In some cases these entitlements may need to be retained for a transition period, but in many instances they should be eliminated immediately. When these types of reviews are not conducted, employees tend to collect more and more entitlements the longer they are employed. This often leads to entitlements combinations that cause separation of duties issues.

There are other types of risk triggers that can be defined based upon employee behavior. For instance, an employee may have an entitlement that allows the transfer of files to external parties. A behavioral rule might be designed to trigger if these transfers suddenly increase in size or frequency, or if they start occurring outside of the employee's normal work hours. This behavior wouldn't necessarily mean that the employee was conducting inappropriate activities, but prudence would dictate a prompt review of the employee's use of that entitlement.

## 10 Identity Repositories Will Move Out of HR

Within most organizations, the natural place to look for identity data is Human Resources. Typical attributes available from HR data systems include date of hire, location, job function, work group, and management chain. Even more important, HR is typically among the first to know of termination dates and the reason



behind them. All of these facts can be used to drive access management decisions, so using HR for this purpose makes a lot of sense.

However, there are two significant problems associated with using the HR database as the primary source of identity data. The most obvious is that HR does not always collect data from everyone that you would like to grant access to your systems. This can include contractors, vendors, and other third parties who are important to the operation of your organization but do not have an employment relationship with your firm. Even when HR does track information for these types of individuals, the quality of the data tends to be far lower than for employees. For instance, HR would not typically know if a contractor had been moved to a project in a completely different department.

This relates to the second problem. HR maintains its data for fundamentally different purposes than for access management. This affects the content, quality, and timeliness of its records, even for employees. For instance, if a lay-off is occurring within an organization, HR will absolutely know when the employee's last day is from a payroll perspective but may not have any record on when the employee should lose access to the organization's computer systems. They may also make use of batch processes that guarantee the information is up-to-date and accurate in time to make payroll decisions but typically payroll is a biweekly or monthly process. If provisioning activities are automated from a HR feed, a multi-week delay would significantly slow onboarding, especially if the onboarding processes have their own lead times. Worse, a multi-week delay in notification of a termination could be disastrous if a disgruntled ex-employee continued to have access after their termination date.

Many organizations have work-arounds for these challenges but it would be far more powerful to maintain an identity aggregation service that is tuned to the needs of IAM. An aggregated storage approach allows for common and consistent routines to be applied across the entire organization and for all types of individuals regardless of their relationship to the organization. This requires that all of the sources of identity be mapped out and that specific steps are taken to ensure that key attributes like employment/assignment status are as accurate and up-to-date as possible regardless of the source. This enables all of the types of identity to be treated the same, facilitating significant reduction in the complexity of managing identities across an environment.

## Conclusion

This chapter has just laid out 10 strong predictions relating to IAM and what businesses should consider as they devise new strategies to manage business processes. And while all predictions are flawed, businesses can and should look beyond to ensure they are prepared for the most likely changes and are making plans to manage them.

The advice to stop, look, and listen given to children before crossing a busy road is apt here. Business communications and data sharing across the Internet and through cloud services have metaphorically been seen as a road. A well thought out and tested strategic identity and access management plan will help you get the most out of today's business technology services and keep you moving, while helping you to avoid costly detours and unexpected ditches.